

Manual 05 - Auditoría y Aseguramiento de IA

CANDIDATO CONTROLADO PARA QA DE PUBLICACION

Revisión de fuente controlada: 647eab3dda4bce3acadc9cd5a0874b354b360935 | Idioma: es-419 | controlled assurance baseline and source watch retained.

Límite de aseguramiento: Este manual de implementación no establece independencia del auditor, competencia profesional, evidencia suficiente y apropiada, cumplimiento legal, certificación, conformidad ni una opinión formal de auditoría. Las conclusiones siguen dependiendo de criterios, evidencia, limitaciones y juicio humano específicos del trabajo.

Rutas de implementación y modelo operativo de auditoría

Manual 05 — Rutas de implementación para auditoría y aseguramiento de IA

Esta sección de implementación proporciona un modelo operativo proporcional para organizaciones que realizan auditoría y aseguramiento de IA. No modifica el requisito de veracidad: toda conclusión debe indicar qué se examinó, contra qué criterios, con qué evidencia, bajo qué limitaciones y por quién.

1. Seleccionar la ruta de aseguramiento

Esencial

Úsela cuando el alcance de IA sea limitado, la complejidad organizacional sea baja, el equipo de auditoría sea pequeño o el trabajo sea una revisión inicial de preparación o interna. Expectativas mínimas:

- mandato, objetivo, criterios y alcance por escrito;
- inventario de sistemas/casos de uso de IA incluidos y responsables;
- solicitud de evidencia y plan de pruebas documentados;
- hallazgos y respuestas de gestión trazables;
- limitaciones de evidencia y riesgo residual explícitos;
- seguimiento de remediación y seguimiento posterior;
- registro de revisor/fecha/decisión.

Estructurada

Úsela cuando existan múltiples sistemas de IA, unidades de negocio, obligaciones regulatorias, proveedores o casos de uso de mayor riesgo. Agregue:

- muestreo basado en riesgo y justificación documentada;
- separación de pruebas de eficacia de diseño y eficacia operativa;
- pruebas del ciclo de vida y gestión de cambios;
- evidencia de linaje de modelo/datos/sistema;
- aseguramiento de proveedores y dependencias;
- pruebas de eficacia de supervisión humana;
- metodología de severidad y análisis de causa raíz;
- revisión independiente de calidad antes del cierre.

Mejorada

Úsela para entornos de alto impacto, relevantes para la seguridad, altamente regulados, sujetos a aseguramiento externo, de escala empresarial o con IA generativa/agéntica compleja. Agregue:

- pruebas técnicas especializadas y desafío independiente;
- liderazgo independiente de auditoría/aseguramiento cuando corresponda;
- muestreo ampliado y controles de calidad de la población;
- evidencia de escenarios, uso indebido, abuso, red teaming, resiliencia, incidentes y reversión;
- mapeo de criterios entre marcos;

- umbrales de escalamiento ejecutivo/directivo;
- validación formal de remediación y análisis de recurrencia;
- paquete de evidencia conservado capaz de soportar escrutinio externo.

2. Enrutamiento por riesgo y complejidad

Gráfico de memoria del Manual 05 1

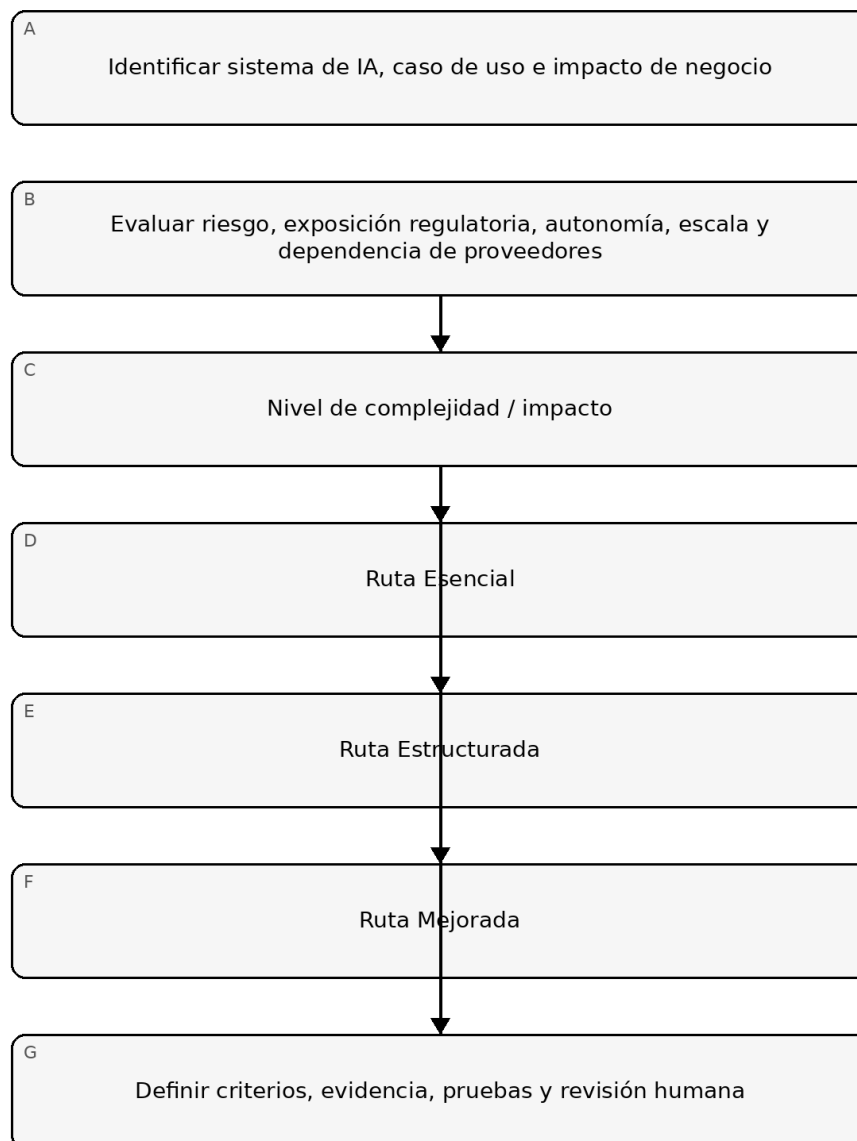


Figure 1. Implementation memory graphic

Explicación accesible: Comience con el sistema o caso de uso de IA y evalúe impacto, exposición regulatoria, autonomía, escala organizacional y dependencia de proveedores. El trabajo de menor complejidad sigue controles Esenciales, el trabajo multisistema moderado sigue controles Estructurados y el trabajo de alto impacto o regulado sigue controles Mejorados. Toda ruta exige criterios, evidencia, pruebas y revisión humana definidos.

3. Ciclo de vida de auditoría

Etapa 1 — Mandato y alcance

Registre patrocinador, autoridad, objetivo, usuarios previstos, consideraciones de independencia, sistemas/casos de uso, ubicaciones, etapas del ciclo de vida, proveedores, exclusiones, período y ruta de reporte. Las exclusiones de alcance no deben ocultarse cuando puedan cambiar la interpretación del resultado.

Etapa 2 — Criterios y plan de evidencia

Los criterios pueden incluir leyes, regulación, obligaciones contractuales, políticas organizacionales, apetito de riesgo aprobado, controles internos, guías NIST, requisitos de sistemas de gestión ISO disponibles bajo la licencia correspondiente u otros requisitos controlados. Registre la fuente/versión y si cada criterio es obligatorio, voluntario, contractual o adoptado internamente.

Para cada objetivo, defina evidencia esperada, población, enfoque de muestra, método de prueba, responsable y tipo de conclusión esperado. Evite pruebas vagas como “revisar gobernanza”. Indique exactamente qué evidencia respaldaría o contradiría el objetivo de control.

Etapa 3 — Trabajo de campo y pruebas

Pruebe combinaciones relevantes de:

- gobernanza y rendición de cuentas;
- inventario de IA y aprobación de casos de uso;
- evaluación de riesgo e impacto;
- procedencia, calidad, privacidad y controles de acceso de datos;
- desarrollo y evaluación de modelo/sistema;
- salvaguardas de IA generativa y agéntica;
- amenazas de seguridad y mitigaciones;
- supervisión humana y escalamiento;
- transparencia y comunicación con usuarios;
- dependencias de proveedores;
- registro, monitoreo, incidentes, reversión y retiro;
- excepciones de política y aceptación de riesgo.

Diferencie evidencia documental de evidencia operativa. Una política por sí sola no demuestra implementación; una captura de configuración por sí sola no demuestra operación sostenida.

Etapa 4 — Hallazgos y severidad

Un hallazgo controlado debe contener:

1. Criterio — requisito o expectativa de control aplicable.
2. Condición — lo que la evidencia demuestra que ocurrió.
3. Causa — por qué existe la brecha, cuando sea sustentable.
4. Riesgo/impacto — por qué importa la condición.
5. Evidencia — registros trazables de respaldo.
6. Alcance/limitación — límites de población/muestra/tiempo.
7. Severidad — usando la metodología aprobada.
8. Responsable — propietario de gestión responsable.

No convierta una observación en falla confirmada sin evidencia suficiente. No reduzca una condición confirmada de alto riesgo solo porque exista remediación planificada.

Etapa 5 — Respuesta de gestión

Registre acuerdo/desacuerdo, justificación, responsable, acción de remediación, fecha objetivo, aceptación/escalamiento de riesgo cuando corresponda y dependencias. La respuesta de gestión no elimina el hallazgo original.

Etapa 6 — Validación de remediación

Valide la acción correctiva contra el hallazgo y su causa raíz. La evidencia debe demostrar que el control modificado está implementado y, cuando corresponda, operando durante un período suficiente. Registre honestamente riesgo residual y remediación parcial.

Etapa 7 — Cierre y seguimiento

Cierre solo cuando se satisfagan los criterios de cierre aprobados. Preserve asuntos no resueltos, excepciones, vínculos de evidencia, decisiones de revisión e indicadores de recurrencia. Cambios materiales de sistema, modelo, datos, proveedor, ley o fuente pueden activar una nueva evaluación.

Gráfico de memoria del Manual 05 2

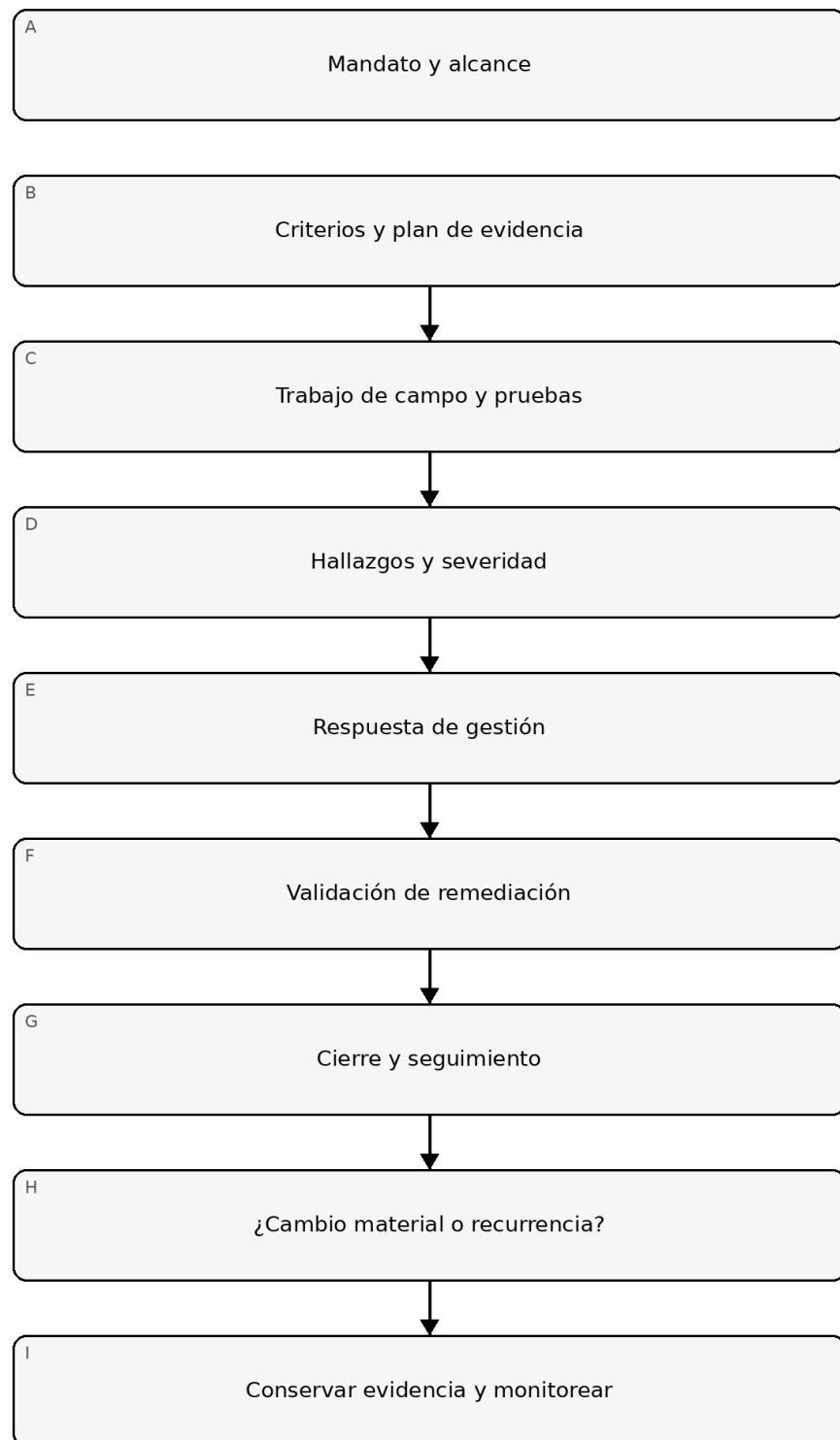


Figure 2. Implementation memory graphic

Explicación accesible: La auditoría comienza con un alcance autorizado, continúa con la planificación de criterios/evidencia, trabajo de campo, hallazgos, respuesta de gestión, validación de remediación y cierre. Un cambio material o recurrencia devuelve el trabajo a una nueva evaluación con alcance definido en lugar de confiar silenciosamente en evidencia anterior.

4. Suficiencia de evidencia y muestreo

El trabajo debe definir la suficiencia de evidencia antes de finalizar conclusiones. Considere relevancia, confiabilidad, integridad, oportunidad, independencia de la fuente, calidad de la población, reproducibilidad y evidencia contradictoria.

El muestreo debe registrar:

- definición de población;
- verificaciones de integridad de población;
- tamaño de muestra y método de selección;
- justificación basada en riesgo o estadística según corresponda;
- excepciones detectadas;
- si las excepciones requieren ampliar pruebas;
- limitaciones de la conclusión.

Para sistemas de IA, la evidencia puede incluir system cards, model cards, evaluaciones de impacto, registros de riesgo, resultados de evaluación, informes de red team, prompts/conjuntos de prueba, configuraciones de guardrails, logs, tickets de incidentes, registros de cambio, registros de acceso, atestaciones de proveedores, contratos, DPIA, aprobaciones, métricas de monitoreo y evidencia de retroalimentación de usuarios. La existencia de un artefacto no demuestra automáticamente eficacia del control.

5. Pruebas técnicas y humanas

El aseguramiento de IA suele requerir evidencia técnica y evidencia de procesos humanos. El trabajo debe determinar si cuenta con competencia para probar:

- comportamiento del modelo/sistema bajo condiciones esperadas y adversas;
- riesgo de alucinación/confabulación cuando sea relevante;
- procedencia e integridad del contenido;
- controles de sesgo/equidad cuando correspondan;
- controles de seguridad y privacidad;
- inyección de prompts y límites de uso de herramientas;
- permisos y autorización de agentes;
- rutas de fuga de datos;
- monitoreo y detección de incidentes;
- mecanismos de detención, reversión, contención y retiro.

Cuando no exista competencia suficiente, registre la limitación o use un especialista calificado. No implique que se realizaron pruebas que no ocurrieron.

6. Independencia, competencia y conflictos

Documente quién diseñó el control, quién lo opera, quién lo probó y quién revisa la conclusión. Auditoría interna, aseguramiento de segunda línea, evaluación de preparación y certificación externa tienen expectativas de independencia distintas. El manual no debe colapsar esas diferencias.

Los controles de conflicto de interés deben abordar auto-revisión, participación de gestión, incentivos de proveedores, participación del equipo de implementación y presión para alterar severidad o conclusiones.

7. Aseguramiento entre marcos

Un solo control de IA puede respaldar múltiples criterios, pero un mapeo no demuestra equivalencia. Los crosswalks deben preservar el significado original del requisito, aplicabilidad, alcance y expectativas de evidencia. Ejemplos de familias de fuentes controladas incluyen ISO/IEC 42001, ISO 19011, ISO/IEC 42006, NIST AI RMF, NIST AI 600-1 y NIST SP 800-53A.

Cuando intervenga un estándar propietario, el repositorio puede resumir conceptos originales de implementación, pero no debe reproducir requisitos protegidos más allá del uso permitido.

8. Modelo de reporte

El informe debe separar:

- conclusión ejecutiva;
- objetivo y alcance del trabajo;
- criterios;
- metodología y muestreo;
- hallazgos confirmados;
- observaciones y recomendaciones;
- limitaciones de evidencia;
- respuestas de gestión;
- disputas no resueltas;
- riesgo residual;
- requisitos de seguimiento;
- límite de aseguramiento.

Una revisión de preparación no debe etiquetarse como certificación. La QA interna no debe etiquetarse como aseguramiento independiente de auditoría. La QA del repositorio no debe presentarse como evidencia de que una organización cumple una ley, marco o estándar.

9. Cadena de evidencia a decisión

Gráfico de memoria del Manual 05 3

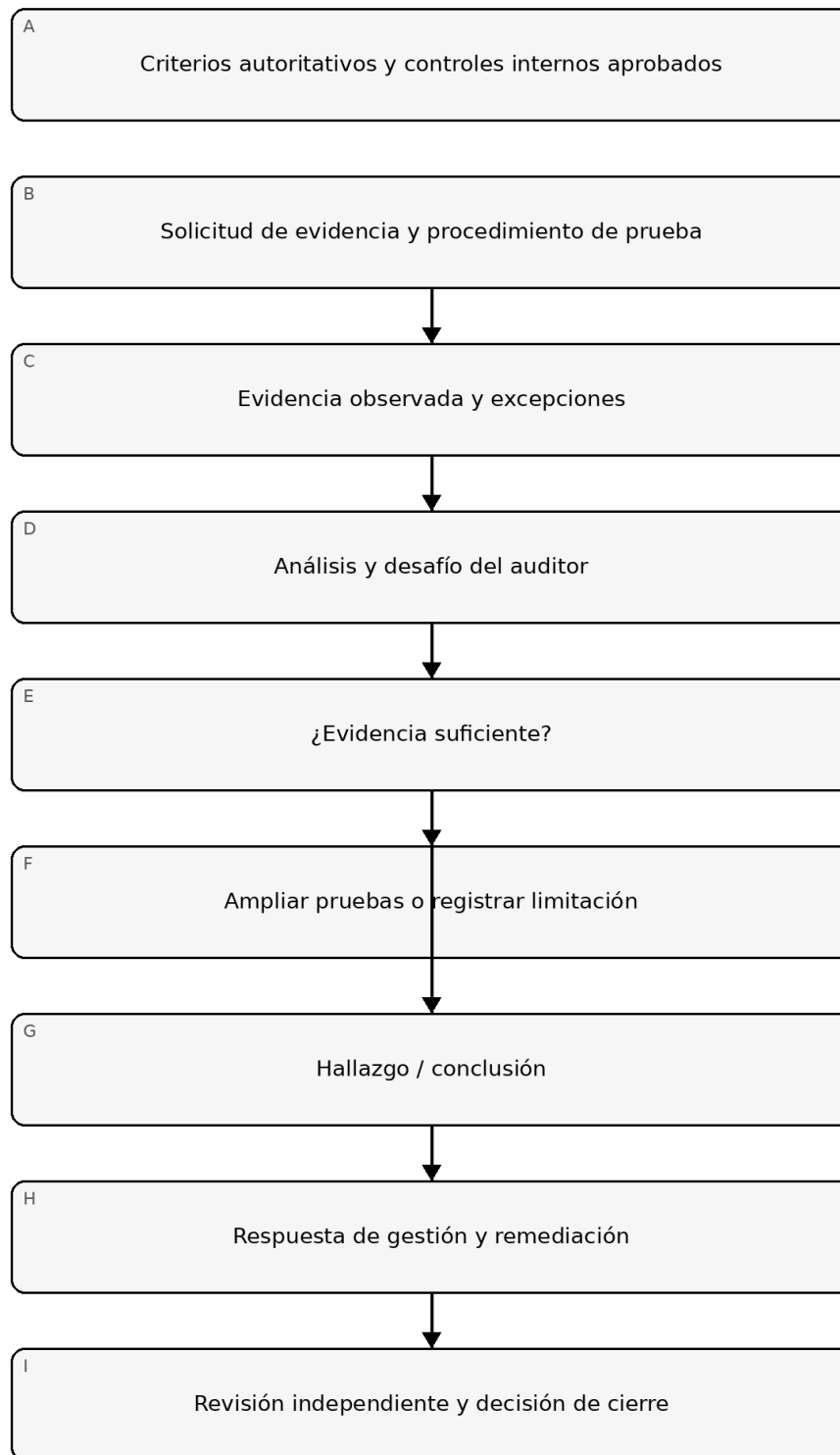


Figure 3. Implementation memory graphic

Explicación accesible: Las conclusiones se originan en criterios controlados, pruebas planificadas y evidencia observada. Si la evidencia es insuficiente, se amplían las pruebas o se registra la limitación. Solo conclusiones suficientemente sustentadas pasan a respuesta de gestión, remediación, revisión independiente y cierre.

10. Evidencia mínima de liberación para este manual

Antes de publicar el Manual 05, el proyecto debe conservar:

- maestro de fuente controlada en inglés;
- verificación de fuentes y registro de estado de fuentes;
- evidencia de revisión editorial/técnica;
- evidencia de revisión semántica de es-419 y pt-BR;
- evidencia de accesibilidad de gráficos;
- evidencia de procesamiento DOCX/PDF;
- QA a nivel de página;
- auditoría de seguridad/repositorio;
- checksums y manifiesto de liberación;
- registros de revisor/fecha/decisión;
- aprobación humana final de liberación.

Pasar verificaciones automatizadas constituye solo evidencia de soporte. El juicio humano sigue siendo obligatorio cuando el marco de control lo exige.

Manual controlado de 32 capítulos

Capítulo 01 — Mandato y objetivo de auditoría

Toda auditoría de IA comienza con un mandato documentado. El mandato identifica quién solicitó el trabajo, por qué se realiza la auditoría, qué decisión apoyarán los resultados, la autoridad del equipo auditor y cualquier restricción de acceso o reporte.

El objetivo de auditoría debe redactarse como una declaración comprobable. “Revisar la gobernanza de IA” es demasiado amplio; “determinar si los sistemas de IA en producción por encima del umbral de alto riesgo de la organización cuentan con responsables aprobados, evaluaciones de riesgo vigentes, evidencia de liberación, monitoreo y aceptación documentada del riesgo residual” es auditable.

Capítulo 02 — Criterios y límite del aseguramiento

Los criterios de auditoría deben identificarse antes del trabajo de campo. Pueden provenir de leyes, regulaciones, contratos, políticas internas, normas aprobadas, compromisos de la dirección, marcos de control o requisitos operativos definidos.

El registro de auditoría debe distinguir los criterios obligatorios de la orientación y las referencias de práctica profesional. ISACA AAIA se utiliza aquí como referencia de práctica profesional para capacidad y cobertura de dominios de auditoría; no es una ley, regulación, norma ISO, certificación organizacional ni una opinión de auditoría.

Capítulo 03 — Alcance y límite del sistema

El alcance debe identificar los sistemas de IA, procesos de negocio, entidades legales, ubicaciones, entornos, período, proveedores, conjuntos de datos, modelos, interfaces y etapas del ciclo de vida incluidos. Las exclusiones requieren justificación.

Las auditorías de IA deben descomponer los sistemas en componentes pertinentes: datos, modelo, prompts, recuperación, herramientas, identidades, infraestructura, monitoreo, revisión humana, proveedores y procesos de cambio. Un alcance limitado al modelo puede omitir riesgos materiales en la orquestación o en acciones posteriores.

Capítulo 04 — Independencia, competencia y conflictos

El líder de auditoría debe evaluar si el equipo posee independencia y competencia suficientes para el objetivo. Las pruebas técnicas de alto impacto pueden requerir especialistas en seguridad, privacidad, ciencia de datos, riesgo de modelos, asuntos legales, accesibilidad, seguridad operacional o el dominio correspondiente.

Los conflictos deben revelarse cuando los auditores hayan diseñado, implementado, aprobado u operado materialmente el control evaluado. Cuando no sea posible una independencia organizacional plena, deben documentarse la limitación y la revisión compensatoria.

Capítulo 05 — Planificación de auditoría y priorización por riesgo

La planificación debe priorizar áreas donde una falla de control pueda causar daño material o donde la calidad de la evidencia sea incierta. Las entradas pueden incluir hallazgos anteriores, incidentes, registros de riesgo, obligaciones regulatorias, criticidad del modelo, sensibilidad de los datos, autonomía, dependencia de proveedores y cambios recientes.

El plan de auditoría debe indicar procedimientos, fuentes de evidencia, enfoque de muestreo, pruebas técnicas, entrevistas, auditores responsables, calendario y entregables esperados.

Capítulo 06 — Estrategia y suficiencia de la evidencia

La evidencia debe ser pertinente al criterio de auditoría y suficientemente confiable para sustentar la conclusión. Las políticas demuestran intención de diseño; no prueban la operación. Las capturas de pantalla muestran un momento específico; pueden no demostrar operación sostenida. Las afirmaciones de proveedores pueden apoyar una conclusión, pero deben corroborarse cuando el riesgo del proveedor sea material.

La evidencia debe evaluarse por pertinencia, confiabilidad, integridad, oportunidad, reproducibilidad cuando corresponda e independencia respecto del propietario del control.

Capítulo 07 — Muestreo y definición de la población

El muestreo comienza definiendo la población. Algunos ejemplos son todos los sistemas de IA en producción, todos los casos de uso de alto riesgo, todas las liberaciones de modelos de un período, todos los proveedores críticos o todos los incidentes que alcancen un umbral de severidad.

El método de muestreo debe reflejar el objetivo y el riesgo de auditoría. El muestreo por juicio puede enfocarse en elementos de alto riesgo; las técnicas estadísticas pueden ser apropiadas para poblaciones homogéneas. Deben revelarse las limitaciones de la muestra y las partes no examinadas de la población.

Capítulo 08 — Ciclo de vida de auditoría y controles de calidad fail-closed

El ciclo de vida controlado de auditoría es:

9. mandato y alcance;
10. criterios y plan de evidencia;
11. trabajo de campo y pruebas;
12. hallazgos y severidad;
13. respuesta de la dirección;
14. validación de remediación;
15. cierre y seguimiento.

Los controles de calidad fallan de manera cerrada cuando la evidencia requerida no está disponible, existen preocupaciones de independencia sin resolver, las pruebas están incompletas, quedan comentarios abiertos del revisor, cambios materiales de alcance invalidan procedimientos o falta una aprobación humana obligatoria.

El QA automatizado del repositorio respalda la consistencia del paquete del manual; no reemplaza el juicio del auditor ni la aprobación humana de publicación.

Capítulo 09 — Procedimientos de auditoría de gobernanza y riesgo

Los auditores deben probar si la gobernanza de IA funciona más allá del lenguaje de las políticas. Los procedimientos deben verificar propiedad responsable, clasificación de riesgo, autoridad de aprobación, escalamiento, manejo de excepciones y revisión periódica para los sistemas incluidos en la muestra.

La evidencia puede incluir inventarios, registros de riesgo, decisiones de comités, aprobaciones de liberación, informes de monitoreo y registros de cambios.

Capítulo 10 — Procedimientos de auditoría de operaciones de IA

Las pruebas operativas deben evaluar despliegue, monitoreo, manejo de incidentes, acceso, control de cambios, mecanismos de respaldo y procesos de retiro. El auditor debe rastrear sistemas seleccionados desde el diseño aprobado hasta su estado actual en producción para determinar si la configuración desplegada coincide con la evidencia que sustentó la liberación.

Capítulo 11 — Procedimientos de auditoría de gobernanza de datos

Las pruebas relacionadas con datos deben abordar procedencia, clasificación, uso permitido, acceso, retención, transformación, controles de calidad, restricciones de privacidad y eliminación cuando corresponda.

Cuando los sistemas de IA dependan de mecanismos de recuperación o almacenes vectoriales, el auditor debe probar cómo se admite, actualiza, elimina y protege el contenido frente a accesos o manipulaciones no autorizados.

Capítulo 12 — Pruebas de modelos y sistemas

Las pruebas de auditoría deben distinguir la evaluación realizada por la dirección de los procedimientos independientes de auditoría. El equipo auditor puede inspeccionar el diseño de pruebas, reproducir pruebas seleccionadas, cuestionar supuestos, ejecutar procedimientos técnicos dirigidos o involucrar especialistas.

Las pruebas deben vincularse con criterios y riesgos definidos, no realizarse únicamente porque exista una herramienta disponible.

Capítulo 13 — Supervisión humana y controles de decisión

Los auditores deben determinar si la revisión humana requerida es realmente posible y está respaldada por evidencia. Los procedimientos pueden examinar competencia del revisor, contexto disponible, autoridad de escalamiento, presión de tiempo, registros de anulaciones, registros de aprobación y si anulaciones repetidas indican debilidad del control.

Capítulo 14 — Aseguramiento de terceros y componentes

El aseguramiento de proveedores debe evaluar la evidencia utilizada para modelos externos, alojamiento, APIs, conjuntos de datos, herramientas y otros componentes materiales. Los procedimientos del auditor deben considerar términos contractuales, informes independientes, evidencia de seguridad, notificaciones de cambios, historial de incidentes, prácticas de datos y riesgo de concentración o salida.

Un cuestionario completado no debe tratarse como equivalente a un aseguramiento respaldado independientemente.

Capítulo 15 — Herramientas técnicas de auditoría y automatización

Las herramientas automatizadas pueden apoyar el análisis de inventarios, verificaciones de configuración, revisión de registros, ejecución de pruebas, muestreo, correlación de evidencia y detección de anomalías. La salida de una herramienta sigue siendo evidencia de auditoría que debe comprenderse, validarse e interpretarse.

Los auditores deben documentar la versión de la herramienta, configuración, población de entrada, limitaciones y cómo se investigaron las excepciones.

Capítulo 16 — Disciplina de papeles de trabajo

Cada conclusión significativa debe poder rastrearse al criterio, procedimiento, evidencia, resultado, preparador y revisor. Los papeles de trabajo deben distinguir hechos observados, declaraciones de la dirección, análisis del auditor, supuestos y limitaciones no resueltas.

Los comentarios materiales del revisor deben resolverse o trasladarse explícitamente al informe antes de cerrar la auditoría.

Capítulo 17 — Desarrollo de hallazgos

Un hallazgo debe conectar criterio, condición, causa, consecuencia y evidencia. Declaraciones vagas como “la gobernanza debería mejorar” no son suficientes. El hallazgo debe identificar qué requisito o expectativa aprobada no se cumplió, qué se observó, por qué importa y qué evidencia respalda la conclusión.

Capítulo 18 — Severidad y priorización

La severidad debe reflejar consecuencia y probabilidad dentro del contexto. Los factores pueden incluir efectos sobre seguridad física, ciberseguridad, privacidad, regulación, finanzas, operaciones, clientes, fuerza laboral y reputación.

El equipo auditor debe utilizar un método consistente de severidad y documentar cuando el juicio profesional prevalezca sobre una puntuación mecánica.

Capítulo 19 — Análisis de causa raíz

El análisis de causa raíz debe distinguir la falla inmediata de la causa sistémica. Algunos ejemplos son propiedad poco clara, diseño de aprobación ineficaz, pruebas insuficientes, gobernanza débil de proveedores, control de cambios deficiente, competencias faltantes o incentivos que eluden los controles.

Una remediación dirigida únicamente al síntoma visible no debe presentarse como corrección de la causa raíz.

Capítulo 20 — Respuesta de la dirección

Las respuestas de la dirección deben indicar acuerdo o desacuerdo, acción prevista, responsable, fecha objetivo y cualquier riesgo residual aceptado. El desacuerdo debe estar respaldado por evidencia o justificación en vez de simplemente eliminar el hallazgo del informe.

Capítulo 21 — Riesgo residual y aceptación

Cuando la remediación no elimine completamente el riesgo, la exposición restante debe documentarse y ser aceptada por una autoridad apropiada a su importancia. El auditor no debe convertir silenciosamente una brecha de control no resuelta en un estado aceptable.

Capítulo 22 — Limitaciones del informe

Los informes deben indicar alcance, período, criterios, procedimientos, limitaciones materiales, brechas de evidencia no resueltas y el significado previsto de la conclusión. Los lectores deben poder distinguir una revisión interna de preparación, evaluación de asesoría, auditoría, actividad de certificación u otro encargo de aseguramiento.

Capítulo 23 — Validación de remediación

El cierre requiere evidencia de que la acción correctiva fue implementada y, cuando corresponda, de que opera eficazmente. La validación puede incluir revisión documental, inspección de configuración, repetición de pruebas, pruebas de muestra, entrevistas u observación.

La afirmación de la dirección por sí sola no debe cerrar un hallazgo material cuando exista evidencia objetiva razonablemente disponible.

Capítulo 24 — Seguimiento y recurrencia

El seguimiento debe considerar si los hallazgos se repiten, si sistemas similares presentan la misma debilidad y si la remediación introdujo nuevos riesgos. Los hallazgos repetidos pueden indicar un problema de gobernanza o del sistema de controles, y no una falla aislada de ejecución.

Capítulo 25 — Revisión de calidad

Antes de emitir el informe, un revisor debe confirmar que las conclusiones significativas están respaldadas por evidencia suficiente, que los cambios de alcance están documentados, que los hallazgos son internamente coherentes y que los comentarios de revisión no resueltos permanecen visibles.

Los encargos de alto impacto deben utilizar independencia del revisor proporcional al riesgo.

Capítulo 26 — Estructura del informe

Los informes deben presentar objetivo, alcance, criterios, métodos, conclusión general, hallazgos, respuestas de la dirección, limitaciones y requisitos de seguimiento. Los resúmenes ejecutivos no deben omitir salvedades materiales que afecten la interpretación.

Capítulo 27 — Lenguaje de aseguramiento

El lenguaje de aseguramiento debe corresponder al encargo realizado. Las evaluaciones de preparación, revisiones de asesoría, auditorías internas, auditorías externas, actividades de certificación y pruebas técnicas no son intercambiables.

El informe debe evitar implicar certificación, cumplimiento legal u opinión formal de auditoría salvo que el encargo proporcione legítimamente ese resultado.

Capítulo 28 — Gobernanza de acciones correctivas

Los hallazgos abiertos deben rastrearse hasta responsables y fechas. Las extensiones deben aprobarse y justificarse. Las acciones vencidas de alta severidad deben escalar a la autoridad de riesgo correspondiente en lugar de permanecer abiertas indefinidamente.

Capítulo 29 — Retención de evidencia de auditoría

La evidencia y los papeles de trabajo deben conservarse de acuerdo con las políticas y requisitos legales, contractuales y profesionales aplicables. El acceso debe restringirse porque la evidencia de auditoría de IA puede contener arquitectura sensible, datos, hallazgos de seguridad, información de modelos o información personal.

Capítulo 30 — Aseguramiento continuo y monitoreo

Cuando el riesgo lo justifique, la auditoría periódica puede complementarse con indicadores continuos o recurrentes de control. El monitoreo automatizado debe tener propiedad definida, umbrales, manejo de excepciones y validación.

El monitoreo continuo no elimina la necesidad de interpretación humana ni de reevaluar periódicamente si los indicadores siguen siendo significativos.

Capítulo 31 — Madurez del programa de auditoría

Un programa maduro de auditoría de IA mantiene un inventario de sistemas, un universo de auditoría informado por riesgos, papeles de trabajo reutilizables, planes de competencia, acceso a especialistas, métodos consistentes de severidad, analítica de hallazgos y lecciones aprendidas.

La madurez debe mejorar la eficiencia sin convertir las auditorías en ejercicios de listas de verificación desconectados del contexto del sistema.

Capítulo 32 — Límite de publicación del manual

Antes de publicar este manual deben completarse la fuente maestra controlada en inglés, la verificación de fuentes autorizadas, la revisión técnica/editorial, la revisión semántica es-419 y pt-BR, la revisión de gráficos/accesibilidad, el QA de DOCX/PDF y de páginas, la procedencia, la auditoría de repositorio/seguridad y la Aprobación Humana Final de Publicación.

Los cambios materiales de contenido posteriores a la aprobación humana reabren los controles de revisión afectados.